

Twitter hack of 2020

In 2020, 130 high-profile Twitter accounts were compromised to promote a bitcoin scam. Twitter confirmed that the perpetrators gained access to Twitter's administrative tools. They used social engineering to gain access to the tools via Twitter employees. Attackers scraped LinkedIn in search of Twitter employees likely to have administrator privileges account-holder tools. Contacted Twitter employees and, using the information from LinkedIn and other public sources, pretended to be Twitter personnel. **Attackers directed victims to log into a fake internal Twitter VPN.** To bypass two-factor authentication, attackers entered stolen credentials into the real Twitter VPN portal, and "within seconds of the employees entering their info into the fake one", asked victims for the two-factor authentication code.

https://en.wikipedia.org/wiki/2020_Twitter_account_hijacking#Method_of_attack





POLITECNICO
MILANO 1863

**DIPARTIMENTO DI ELETTRONICA
INFORMAZIONE E BIOINGEGNERIA**

POLITECNICO MILANO 1863

NECST
laboratory



Social Engineering

What is social engineering?

Why social engineering?

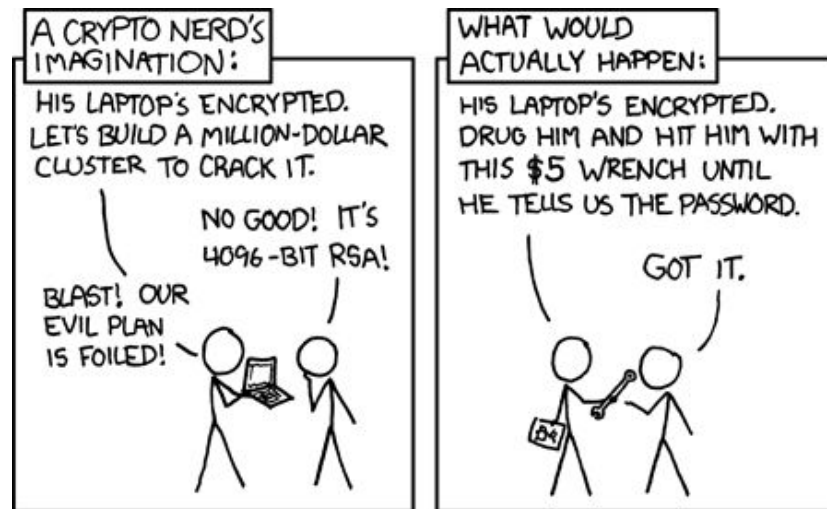
- Technology vulnerabilities are hardened, patched, or solved.
- S.E. is often the path of least resistance

“Why spend hours, days, weeks to crack a password when you can just ask for it?”
- Technologies hardly prevent S.E.

Hence, it is usually **simpler, faster** and **cheaper**.

“You could spend a fortune purchasing technology and services from every exhibitor, speaker and sponsor at the RSA Conference, and your network infrastructure could still remain vulnerable to old-fashioned manipulation.”

–Kevin Mitnick



Unnecessary statistics

Cyber Security Statistics

600%

The rate that **cybercrime** increased during the COVID-19 pandemic.



\$6 trillion

The **expected 2021 total cost** worldwide of all **cybercrime damages**.



Phishing attacks account for **90%** of all data breaches



95%

of organizations claim to provide phishing awareness training, but

30%

trained just a portion of their user base



90%

of **healthcare staff** in 2020 did not receive any **updated cyber security training** while working from home due to the COVID-19 pandemic



233 days

The average time financial institutions took to **detect and address data breaches**



Only about 3% of malware tries to exploit an exclusively technical flaw. The other **97%** involves targeting users through social engineering

For more than 90% of the successful attacks human are the “**kill switch**”. This means that without the human error the attack won't start

The number of successful attacks has risen from 62% in 2014, to 71% in 2015, to 76% in 2016, and to 79% in 2017 with no end in sight. **91% of these attacks use spear phishing.**

<https://www.dogana-project.eu/index.php/social-engineering-blog/11-social-engineering/94-estimates-of-social-engineering-attacks>

Common social engineering attacks?

Common social engineering attacks?

Greetings to you my friend,

I know this will come to you as a surprise. I do not know me.
I am John Alison I work in Central Bank of Nigeria packaging and courier department.

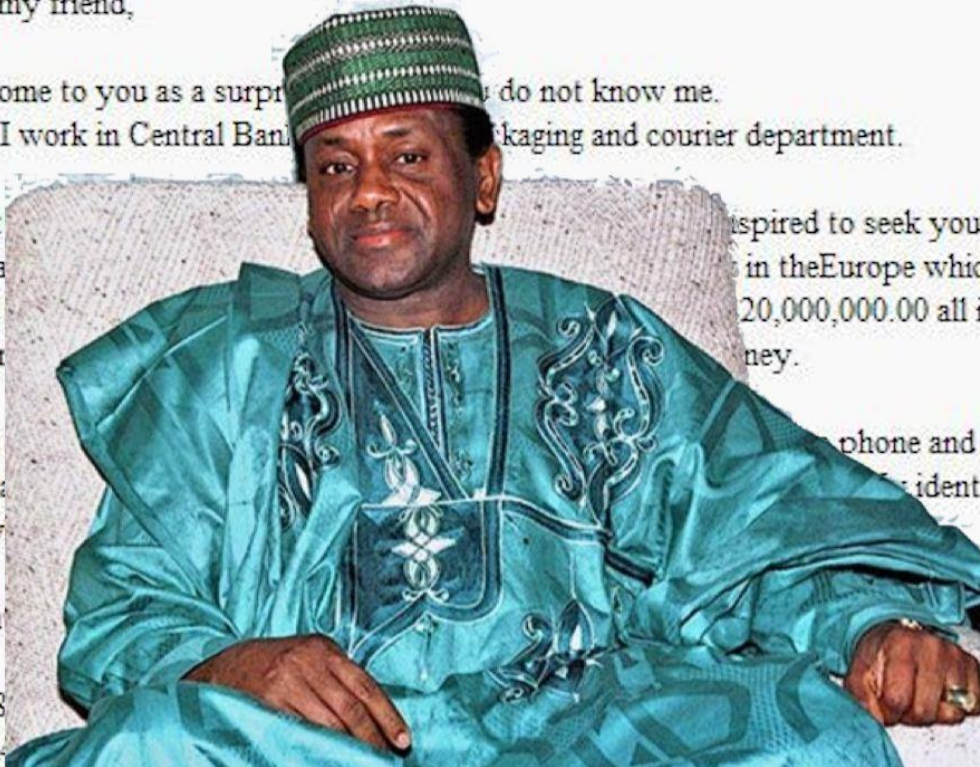
I got your contact details through our CBN website. I was inspired to seek your
co-operation, I was in the Europe which I shipped
through our CBN website. I was in the Europe which I shipped
20,000,000.00 all in \$100 bills,
but the courier company lost the money.

All I want you to do is to provide me with your phone and fax number,
and I believe that your identity must not
be revealed to any one.

If this arrangement

Phone: +234 8028

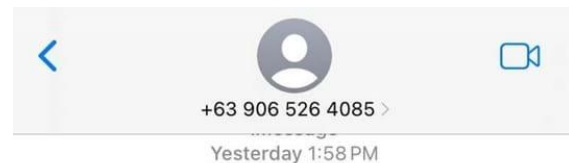
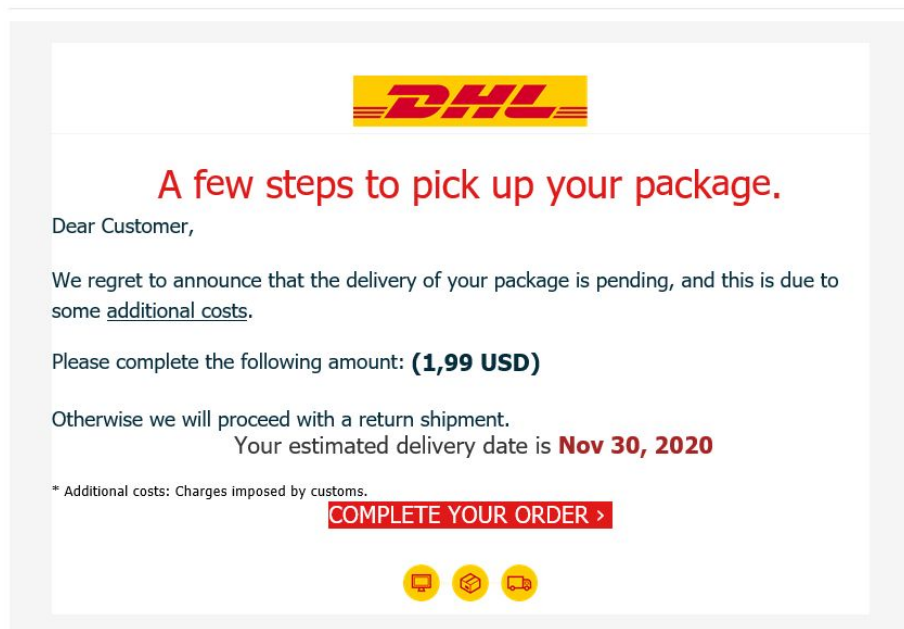
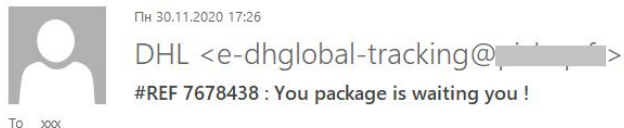
Email: john_alison



Common social engineering attacks?



Common social engineering attacks?



The USPS package arrived at the warehouse but could not be delivered due to incomplete address information. Please confirm your address in the link.

<https://usps.rpostei.com>

(Please reply Y, then exit the text message and open it again to activate the link, or copy the link and open it in your Safari browser).

The USPS team wishes you a wonderful day!

Social Engineering is not only “cheap scams”

- The Uber Hack of september 2022
- \$100M Fraud towards Google and Facebook
- Russia Hacking Campaign against Ukraine w/ spear phishing
- \$250K Deepfake Vishing attack against UK Company
- \$13M Whaling Attack against Belgian Bank
- ...

So how do we define social engineering?

“Any act that **influences** a person to take an action that may or may not be in their best interest”

- Christopher Hadnagy

Social engineering uses influence and persuasion to deceive people by convincing them that the social engineer is someone he is not, or by manipulation. As a result, the social engineer is able to take advantage of people to obtain information **with or without the use of technology**”

- KEVIN D. MITNICK & William L. Simon - Art of Deception

“Social engineering refers to all techniques aimed at talking a target into **revealing specific information or performing a specific action** for illegitimate reasons.”

- ENISA (European Union Agency for Cybersecurity)

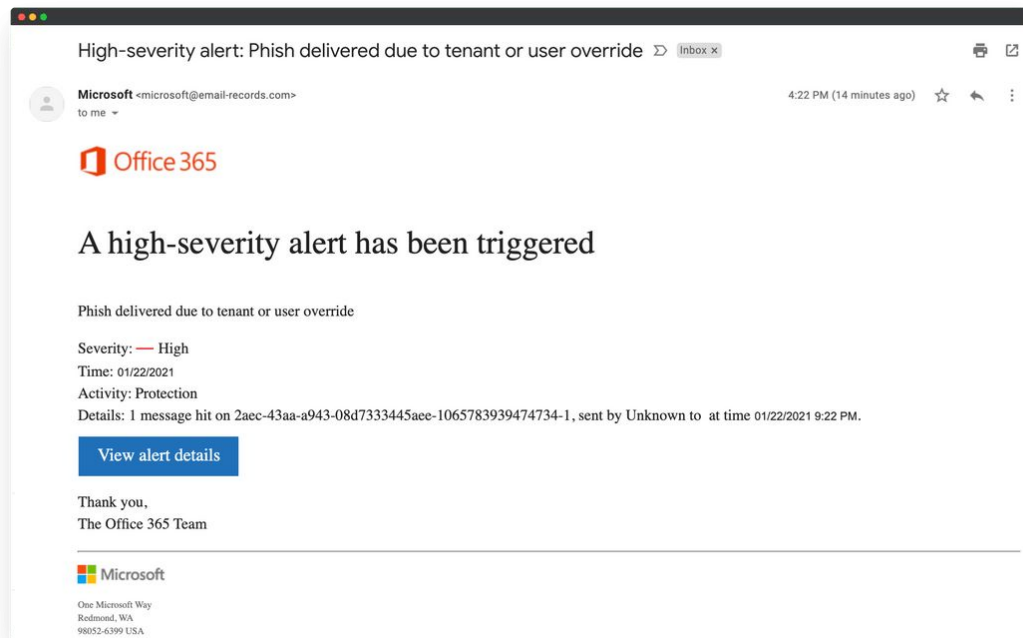
What is social engineering?

Social Engineering is the **medium**, not the **objective**.

More specifically, it is a **category of attacks**, of techniques to obtain specific goals. Each can be considered an attack vector, available every time there is some kind of human interaction in the attacked system. These can be used both by themselves, both as a step of a bigger attack, which may or may not include the use of other techniques.

How does it look from the target's side?

What allows the attacker to change the victim's goals?

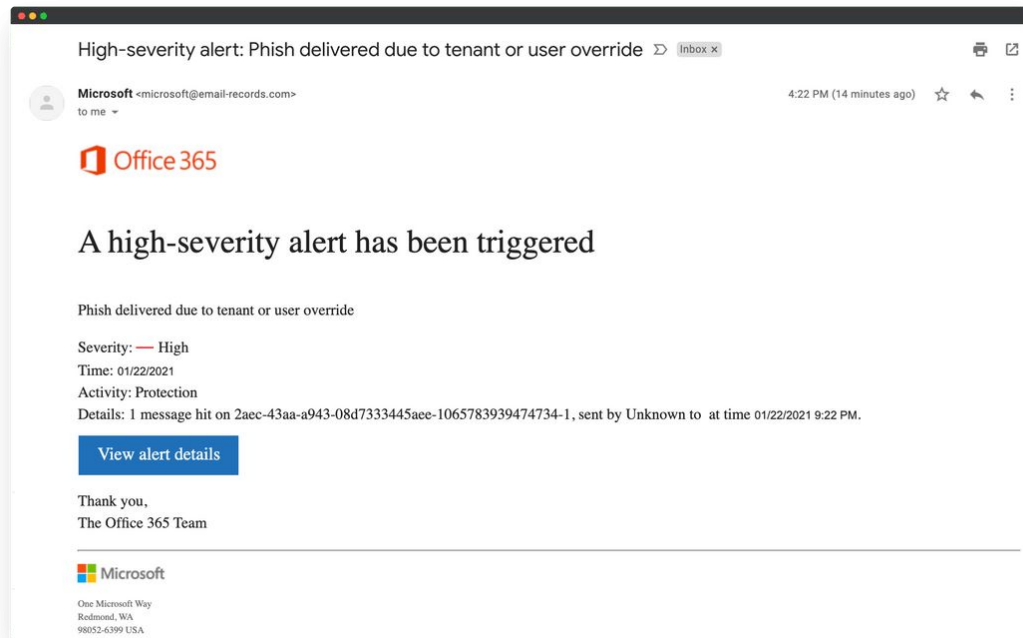


How does it look from the target's side?

What allows the attacker to change the victim's goals?

The attacker understands human behavior (**knowledge**).

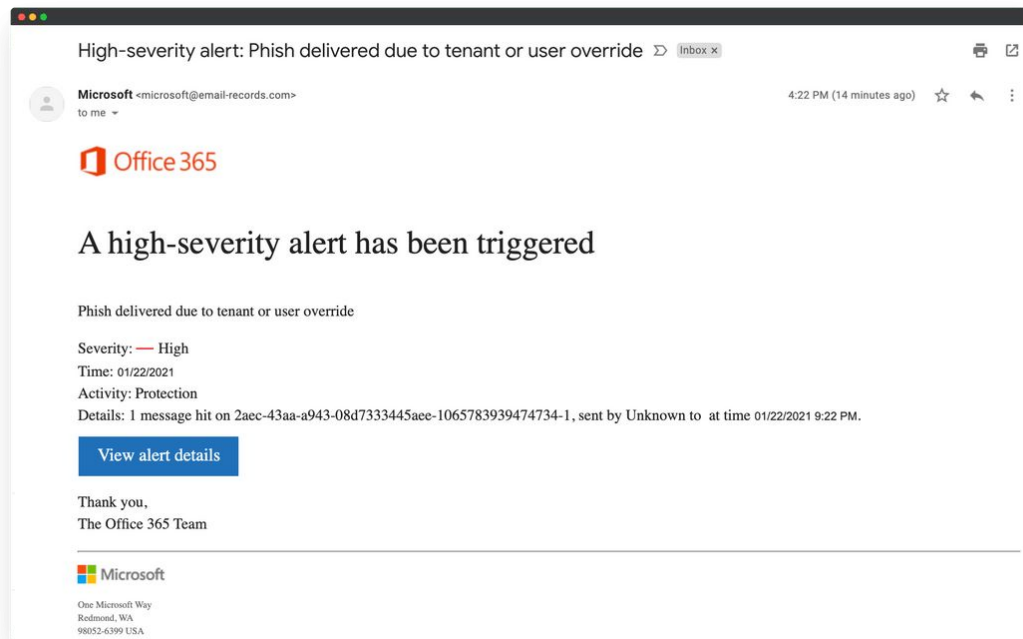
The attacker has technical skills to trigger the wanted human behavior (**technical advantage**).



How does it look from the target's side?

What allows the attacker to change the victim's goals?

Wrong assumptions lead the victim to build an incorrect model of the environment.





POLITECNICO
MILANO 1863

**DIPARTIMENTO DI ELETTRONICA
INFORMAZIONE E BIOINGEGNERIA**

POLITECNICO MILANO 1863

NECST
laboratory



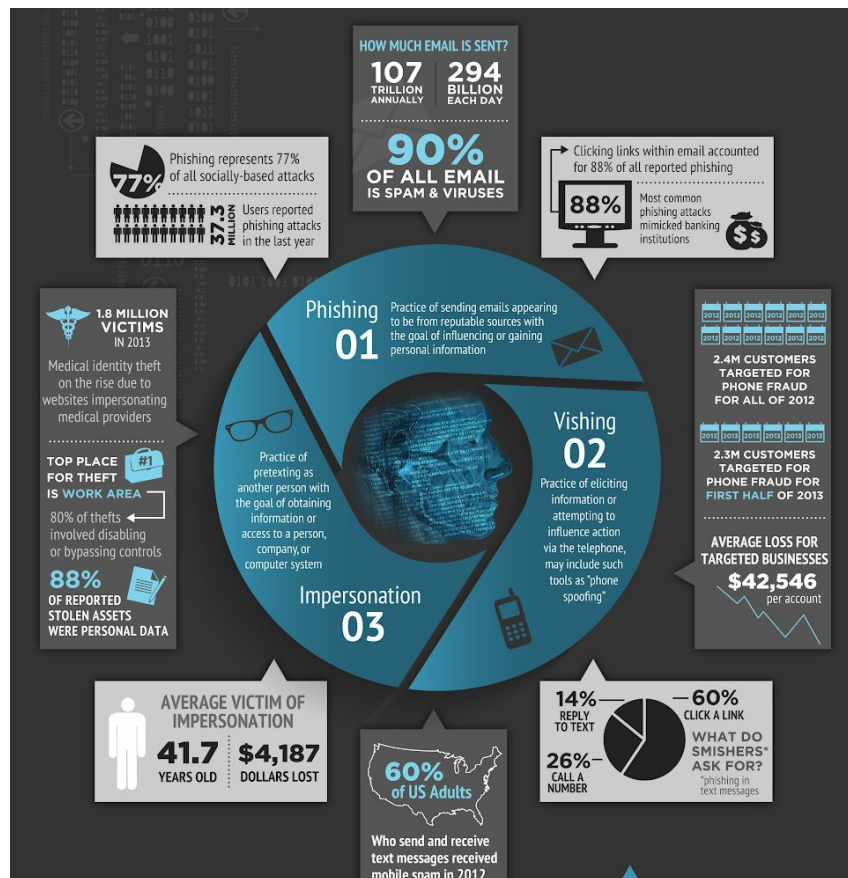
Social Engineering Attack Vectors

Categories

Phishing

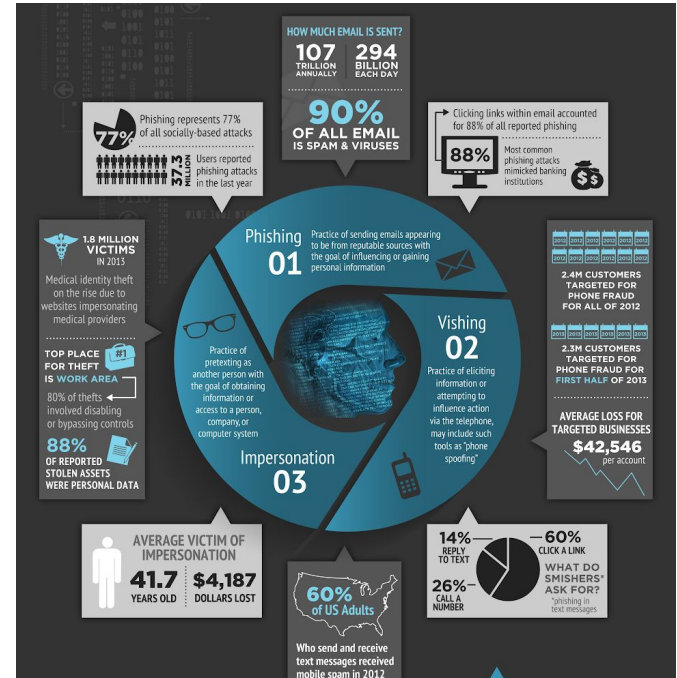
Vishing

Impersonation



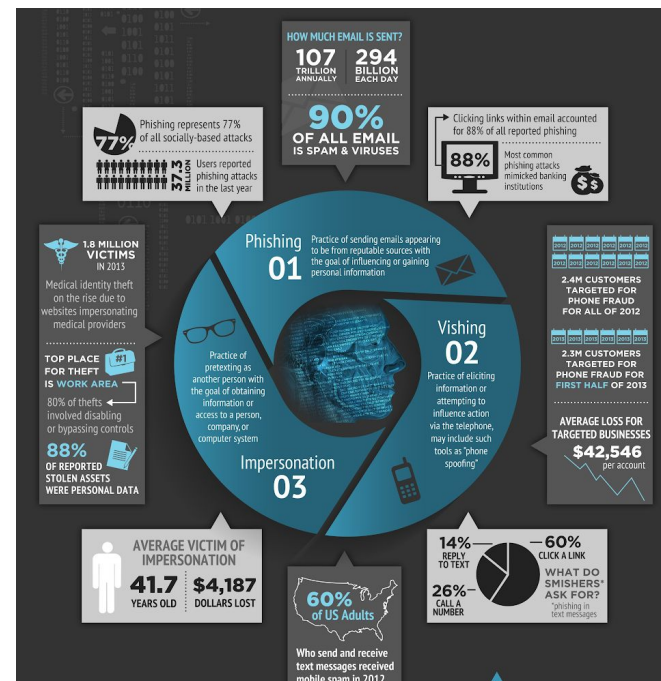
Impersonation

- Most common goal is to access premises
- (as much as i don't like it) common attacks:
 - shoulder surfing
 - piggybacking/tailgating
- Assumptions to play on / Spoofing options:
 - Wearing ad-hoc clothes, e.g., repairman
 - Playing on the access level you already obtained
 - Copying access credentials (more on this later)
- Countermeasures
 - Perimeter security
 - Personnel education



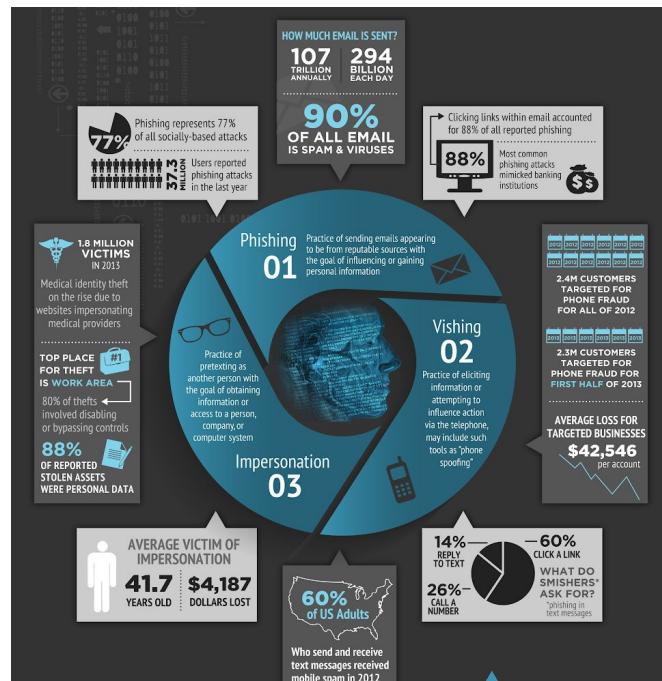
Vishing

- Most common attack goals are to obtain information or force-install something
- Assumptions to play on / Spoofing options:
 - Spoofing caller-ID through VoIP
 - Spoofing caller's name
 - instant messaging call options
- Countermeasures
 - Technologically, not many (may be implemented by the phone provider)
 - Education (e.g., teach to call back instead)



Phishing

- Vastly the most common vector, objectives vary:
 - Financial fraud
 - Information theft
 - Coercion / Blackmail / Extortion
 - Malware delivery
- Implementation means:
 - email
 - instant messaging services
 - social media chats
- Common attacks:
 - Spear phishing / Whaling
 - Angler phishing
- Assumptions to play on / Spoofing options:
 - Logos / message structure copying
 - Email sender field or actual sender spoofing
 - Impersonating on social media
 - Using stolen accounts



Pros, cons, and considerations?

Risks e.g., impersonation requires physical presence

Reach e.g., impersonation allows physical access

Scale e.g., phishing can parallelize attacks

Effectiveness / Complexity e.g., impersonation allows more control on the interaction than phishing, but also requires more expertise

Technical support e.g., spoofing email addresses may support the attack

A note on phishing quizzes:

<https://phishingquiz.withgoogle.com/?hl=en>

<https://www.opendns.com/phishing-quiz/>

<https://www.phishingbox.com/phishing-iq-test>

good and bad points delivered through these...



POLITECNICO
MILANO 1863

**DIPARTIMENTO DI ELETTRONICA
INFORMAZIONE E BIOINGEGNERIA**

POLITECNICO MILANO 1863

NECST
laboratory



Social Engineering Building Blocks

Building Blocks

The final goal of the attacker derives from the definition
(convince the victim to execute a specific action)

To obtain the action, you need to **influence** the victim

To influence the victim you need to have its **trust**

To have its trust you need **knowledge**

Building Blocks

The final goal of the attacker derives from the definition
(convince the victim to execute a specific action)

To obtain the action, you need to **influence** the victim

To influence the victim you need to have its **trust**

To have its trust you need **knowledge**

3) Influence tactics

2) Pretexting

1) Information Gathering



POLITECNICO
MILANO 1863

**DIPARTIMENTO DI ELETTRONICA
INFORMAZIONE E BIOINGEGNERIA**

POLITECNICO MILANO 1863

NECST
laboratory



Building Block: Influencing others

Getting someone to want to do what you want them to do
-Christopher Hadnagy

Principles of Influence: Reciprocity

According to Cialdini[1], our brains are unsettled until we repay a favor.

Experiments by Regan[3] show that a small favor may be more relevant than how much the experimenter was liked by the subject.

Note that the level of an “acceptable request” is dependent on the **perceived value** of your gift by the receiver. Hence, knowing your victim’s tastes and interests goes a great length here.

Similar concept is that of **Obligation** but based on social norms or expected behavior, not on previous favors or gifts.

[1] Cialdini, Robert B., and Robert B. Cialdini. *Influence: The psychology of persuasion*. Vol. 55. New York: Collins, 2007.

[2] <https://www.wiley.com/en-us/Social+Engineering%3A+The+Science+of+Human+Hacking%2C+2nd+Edition-p-9781119433750>

[3] Regan, D. T. “Effects of a Favor and Liking on Compliance.” *Journal of Experimental Social Psychology* 7 (1971): 627–39.

Principles of Influence: Scarcity

If something is made scarce, or less available, its perceived value increases.

A bunch of experiments have been done on the effects of scarcity, e.g., Worchel et al.[4].

Results shown that cookies in scarce supply were rated as more desirable, especially when they decreased in quantity due to high demand.



[1] Cialdini, Robert B., and Robert B. Cialdini. *Influence: The psychology of persuasion*. Vol. 55. New York: Collins, 2007.

[2] <https://www.wiley.com/en-us/Social+Engineering%3A+The+Science+of+Human+Hacking%2C+2nd+Edition-p-9781119433750>

[3] <https://www.ign.com/articles/magic-the-gathering-the-one-ring-lord-of-the-rings-card-2-million-post-malone>

[4] Worchel, S., Lee, J., & Adewole, A. (1975). Effects of supply and demand on ratings of object value. *Journal of Personality and Social Psychology*, 32(5), 906–914. <https://doi.org/10.1037/0022-3514.32.5.906>

Principles of Influence: Authority

Authority is the right to exercise power. Society teaches us to follow authorities' orders.
Authority can be: Legal; Organizational; Social

Milgram [3] showed in an experiment the effectiveness of authority (https://en.wikipedia.org/wiki/Milgram_experiment)

The volunteer was told that the experiment was on memory and learning

He was put in a room as the “teacher”. Another (fake) volunteer was the student.

A third person entered as the “experimenter”, in a lab coat (**authority**).

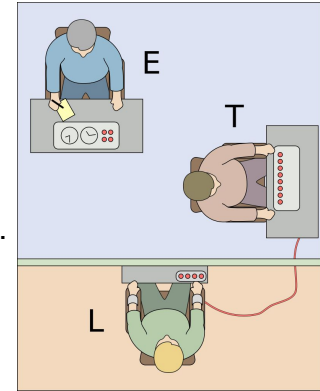
The teacher was to ask the student word pairs, and the student would get electrocuted if wrong.

For each error, the (fake) voltage increased (from 45 to 450 volts).

The student was to make audible protests and fake being in pain.

If the volunteer indicated a desire to halt the experiment, the experimenter said words like “please go on”.

All participants went up to 300V, with 65% to 450V.



[1] Cialdini, Robert B., and Robert B. Cialdini. *Influence: The psychology of persuasion*. Vol. 55. New York: Collins, 2007.

[2] <https://www.wiley.com/en-us/Social+Engineering%3A+The+Science+of+Human+Hacking%2C+2nd+Edition-p-9781119433750>

[3] Milgram, Stanley. "Behavioral study of obedience." *The Journal of abnormal and social psychology* 67.4 (1963): 371.

Principles of Influence: Consistency & Commitment

It is “innatural” to disagree with yourself.

After making a commitment, taking a stand or position, people are more willing to agree to requests that are consistent with their prior commitment.

“Foot-in-the-Door” experiment by Freedman & Fraser [3]: homeowners were asked to put a large and unattractive “Drive Safely” sign in their front yard.

Some were previously asked to put a small “drive safely” sticker on their cars.

Only 17% of people asked directly to put the yard sign agreed.

76% of those that were asked to put the sticker first accepted to put the yard sign.

[1] Cialdini, Robert B., and Robert B. Cialdini. *Influence: The psychology of persuasion*. Vol. 55. New York: Collins, 2007.

[2] <https://www.wiley.com/en-us/Social+Engineering%3A+The+Science+of+Human+Hacking%2C+2nd+Edition-p-9781119433750>

[3] Freedman, J. L., & Fraser, S. C. (1966). Compliance without pressure: The foot-in-the-door technique. *Journal of Personality and Social Psychology*, 4(2), 195–202. <https://doi.org/10.1037/h0023552>

Principles of Influence: Liking

People like people who are like them.

Hence, trivially, if you manage to use everything we mentioned to make the victim like you, they'll be more prone to help you or accommodate your requests, often even salespeople try to find common ground to build rapport.

Cialdini [1] presents the example of tupperware parties, where instead of having a salesman invite people to gatherings, the process involved a “host” e.g., a friend or neighbor inviting people to their home for a party.

[1] Cialdini, Robert B., and Robert B. Cialdini. *Influence: The psychology of persuasion*. Vol. 55. New York: Collins, 2007.

[2] <https://www.wiley.com/en-us/Social+Engineering%3A+The+Science+of+Human+Hacking%2C+2nd+Edition-p-9781119433750>

Principles of Influence: Social Proof

If you don't know what to do, act like you belong.

When people are unable to determine the appropriate mode of behavior, it is easy if you see others acting or talking a certain way, to assume that is appropriate.

Example study:

https://www.youtube.com/watch?v=TYIh4MkcfJA&ab_channel=eqivideos

In social engineering, you may have a partner participating in the same interaction before the victim, or build up a claim that you did that interaction with many people before and it went well.

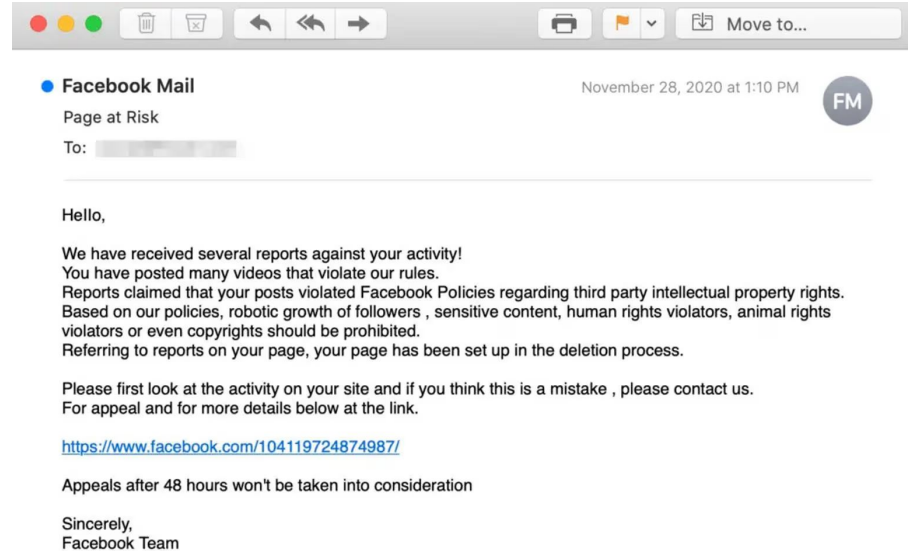
[1] Cialdini, Robert B., and Robert B. Cialdini. *Influence: The psychology of persuasion*. Vol. 55. New York: Collins, 2007.

[2] <https://www.wiley.com/en-us/Social+Engineering%3A+The+Science+of+Human+Hacking%2C+2nd+Edition-p-9781119433750>

Fear

Fear is an effective tactic due to two main effects:

- a) It activates the amygdala, triggering the fight-or-flight response, which limits rational thinking.
- b) It creates urgency, forcing the user to make a choice without verifying the provided information.



[1] Öhman, Arne. "The role of the amygdala in human fear: automatic detection of threat." Psychoneuroendocrinology 30.10 (2005): 953-958.



POLITECNICO
MILANO 1863

**DIPARTIMENTO DI ELETTRONICA
INFORMAZIONE E BIOINGEGNERIA**

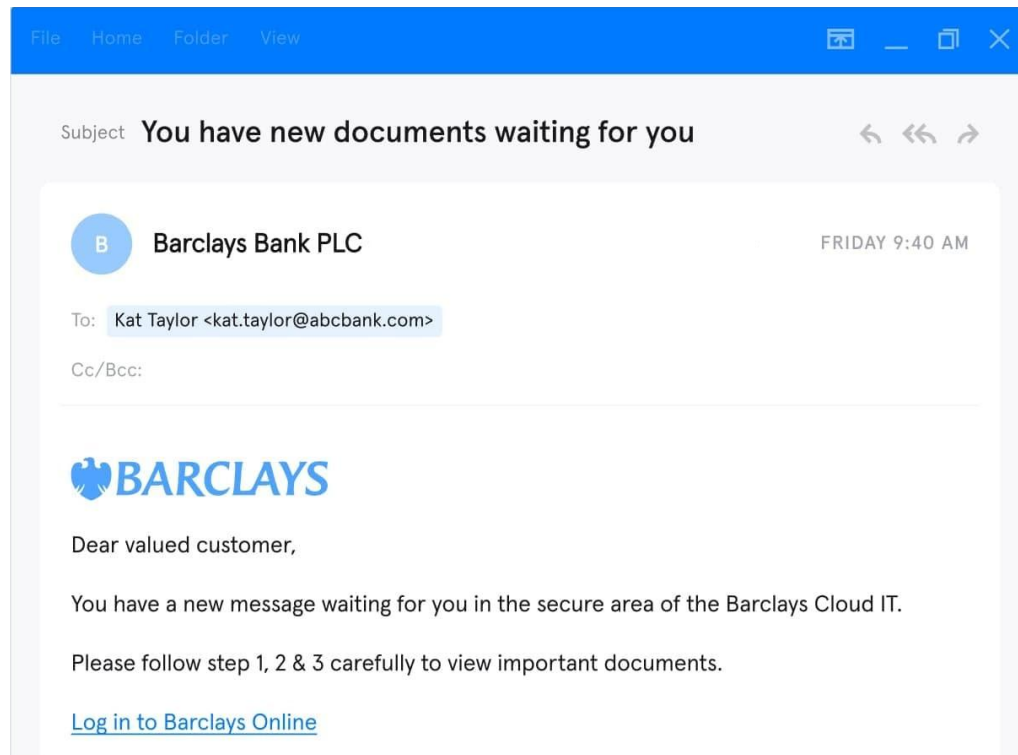
POLITECNICO MILANO 1863

NECST
laboratory

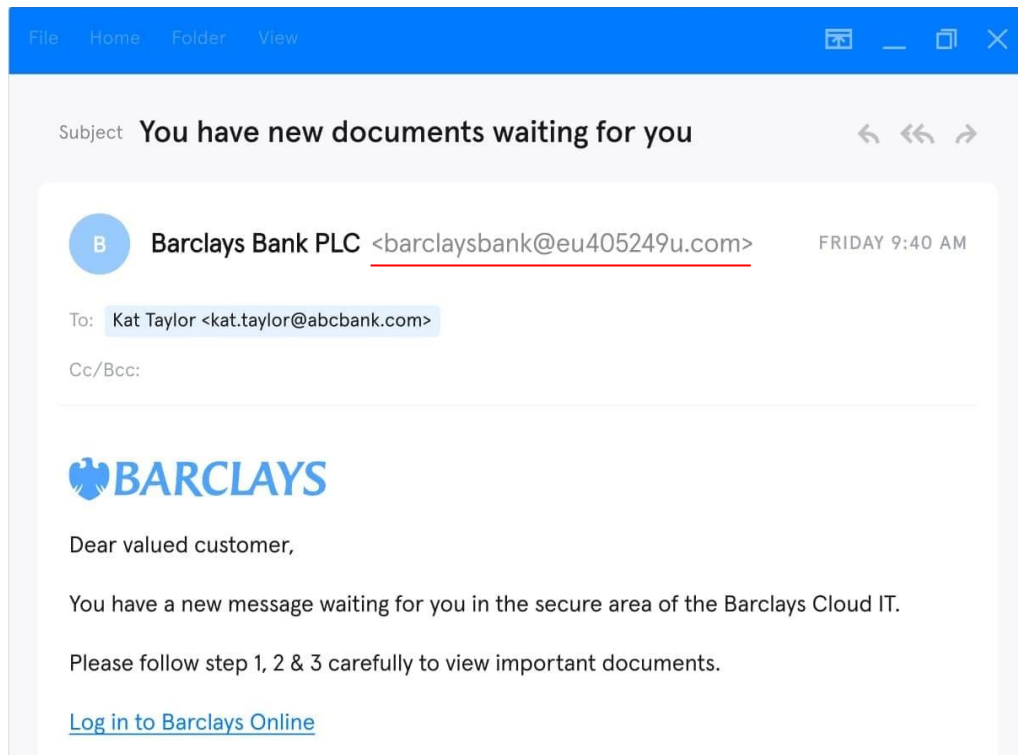


AI in Social Engineering

Assumptions are the foundation of S.E. attacks



Assumptions are the foundation of S.E. attacks



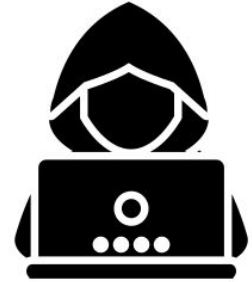
How does AI affect Social Engineering?



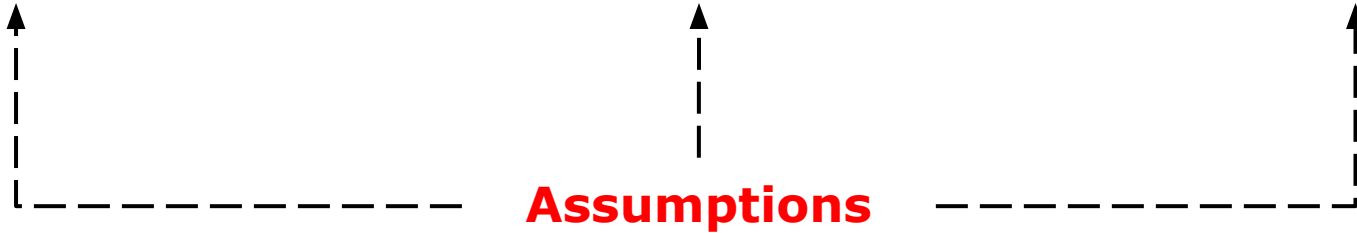
Assets



Attack Vectors



Attacker Models



What happens to the various attack vectors?



Assets



Attack Vectors



Attacker Models



Assumptions

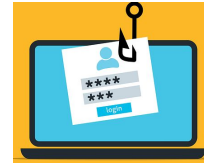
Impersonation



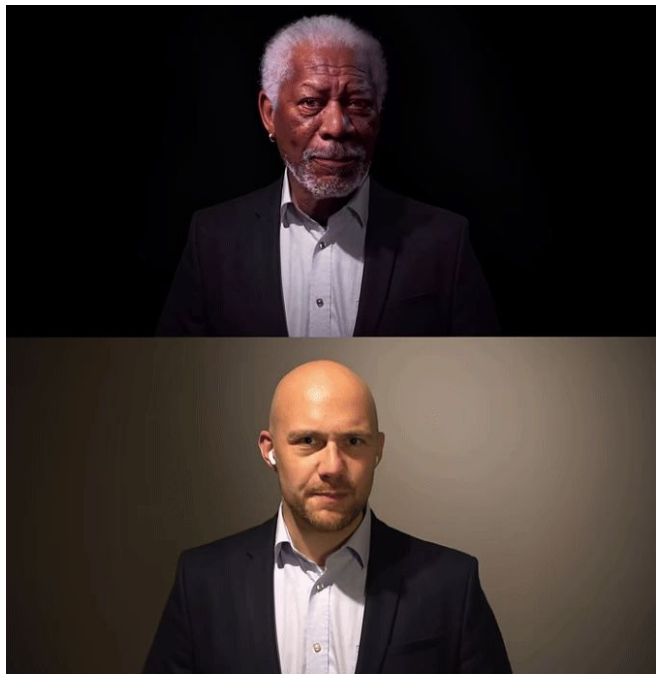
Vishing



Phishing

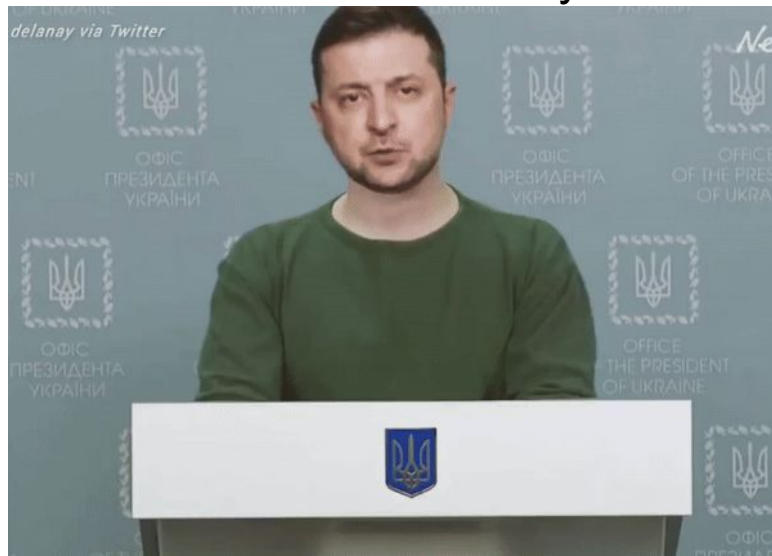


Assumptions in Impersonation: DeepFakes



2021

Seeing a person is not a way to
authenticate them anymore



2022

Assumptions in Impersonation: DeepFakes

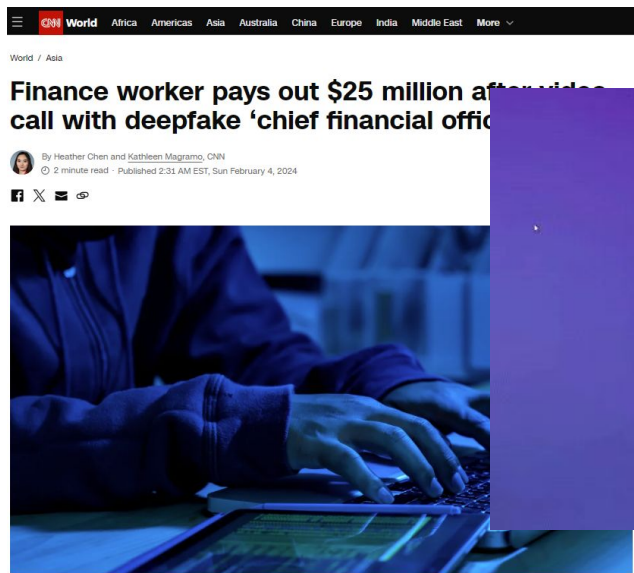


2020



2021

Assumptions in Impersonation: DeepFakes

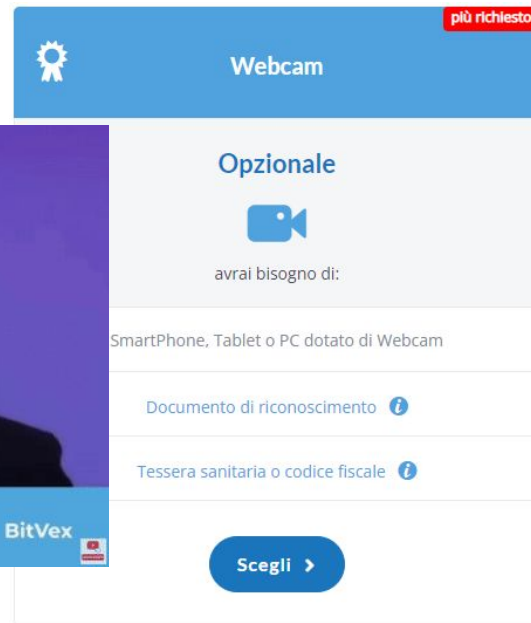


Authorities are increasingly concerned at the damaging potential posed by artificial intelligence technology. boonchai wedmakawand/Moment Rf/Getty Images

2024

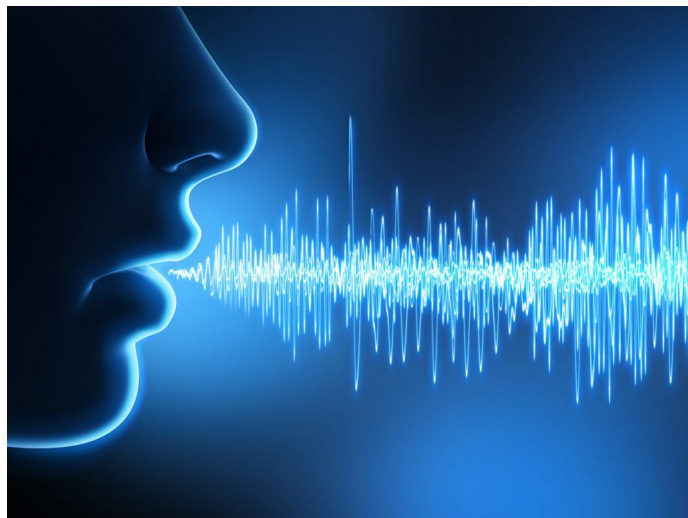


2024

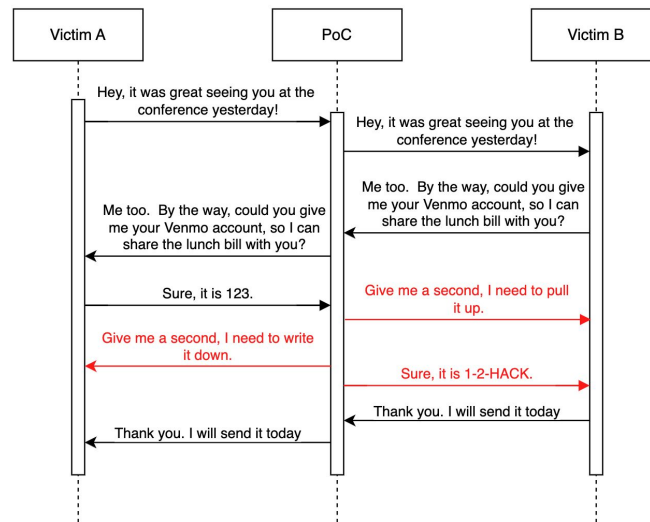


Assumptions in Vishing : Audio-Jacking

MITMs can be implemented in vishing attacks



How Audio-jacking Works



2024

Assumptions in Phishing: Automatic Spear-Phishing

Large-scale phishing can now be tailored and access personal information

Weaponizing Data Science for Social Engineering:
Automated E2E Spear Phishing on Twitter

John Seymour | Philip Tully

 **ZEROFOX**

#SNAP_R

1

2016

Large Language Model Lateral Spear Phishing: A Comparative Study in Large-Scale Organizational Settings

Mazal Bethany
Department of Information Systems
and Cyber Security
University of Texas at San Antonio

Athanasios Galic
Department of Information
and Cyber Security
University of Texas at San Antonio

Nishant Vishwamithr
Department of Information
and Cyber Security
University of Texas at San Antonio

Large Language Models (LLMs) have revolutionized natural language processing (NLP) and have found applications in various domains, including cybersecurity. This paper explores the potential of LLMs in spear phishing attacks, specifically focusing on the generation of highly personalized and convincing phishing emails. We compare the effectiveness of LLM-generated emails against traditional phishing methods, examining factors such as email content, structure, and the ability to bypass security filters. Our findings suggest that LLMs can significantly enhance the sophistication of spear phishing campaigns, posing a new challenge for organizational security measures. We discuss the implications of these findings and propose potential countermeasures to mitigate the risks associated with LLM-powered phishing attacks.

LARGE LANGUAGE MODELS CAN BE USED TO EFFECTIVELY SCALE SPEAR PHISHING CAMPAIGNS

Oxford Internet
Centre
julian.hazell

SPEAR PHISHING WITH LARGE LANGUAGE MODELS

Julian Hazell
Oxford Internet Institute, University of Oxford
Centre for the Governance of AI
julianchristianhazell@gmail.com

December 14, 2023

ABSTRACT

Recent progress in artificial intelligence (AI), particularly in the domain of large language models (LLMs), has resulted in powerful and versatile dual-use systems. This intelligence can be put towards a wide variety of beneficial tasks, yet it can also be used to cause harm. This study explores one such harm by examining how LLMs can be used for spear phishing, a form of cybercrime that involves manipulating targets into divulging sensitive information. I first explore LLMs' ability to assist with the reconnaissance and message generation stages of a spear phishing attack, where I find that LLMs are capable of assisting with the email generation phase of a spear phishing attack. To explore how LLMs could potentially be harnessed to scale spear phishing campaigns, I then create unique spear phishing messages for over 600 British Members of Parliament using OpenAI's GPT-3.5 and GPT-4 models. My findings provide some evidence that these messages are not only realistic but also cost-effective, with each email costing only a fraction of a cent to generate. Next, I demonstrate how basic prompt engineering can circumvent safeguards installed in LLMs, highlighting the need for further research into robust interventions that can help prevent models from being misused. To further address these evolving risks, I explore two potential solutions: structured access schemes, such as application programming interfaces, and LLM-based defensive systems.

Keywords: Artificial Intelligence - AI Policy - Cybersecurity

2023 - 2024

A note on countermeasures

Attack Detection
Systems



Content Authentication



Education and
Awareness



Recap

	Approach	Limitations/Weaknesses
SPF	Verifies sending server's IP address	Fails with email forwarding Does not verify the "From" header in the data field
DKIM	Checks email integrity through signatures.	Requires key management Not all the email is signed to allow forwarding and other modifications.
DMARC	Builds on top of SPF and DKIM Validates the alignment of senders Allows the sender domain to define the policy to apply	% of emails to ignore may lead to attacks

Note that there are other policies, e.g., spam scores, IP blocklists, and other tools that specific email providers may utilize. However, important to clarify that **if the spoofed domain** does not implement any approach, there's nothing that can really be done on the receiver side.